

Tổng hợp lỗi đã xác nhận

1. Phạm vi và trạng thái

Tài liệu này tổng hợp tám lỗi độc lập PB-01 đến PB-08 từ kết quả chạy Newman thật, phân tích nguyên nhân gốc và quyết định duyệt của người thực hiện. Nhiều assertion thất bại do cùng một hành vi chỉ được tính là một lỗi.

Tất cả tám lỗi có trạng thái:

CONFIRMED_BY_HUMAN_REVIEW

Các GitHub Issue #1 đến #8 đã được tạo trong repository [SieuNhanGao889/hcmus_api_assignments](#) và đang ở trạng thái OPEN tại thời điểm đối chiếu ngày 2026-08-21. Ảnh tổng thể danh sách issue: [githubissues.png](#).

2. Thống kê tổng quan

Chỉ số	Giá trị
Tổng số lỗi đã xác nhận	8
CRITICAL	1
HIGH	5
MEDIUM	2
GitHub Issue đã tạo	8
GitHub Issue đang mở	8
Ảnh bằng chứng riêng cho từng lỗi	8

Phân bố theo API bị ảnh hưởng:

API	Bug liên quan	Số lượng
POST /api/login	PB-01, PB-02, PB-03	3
POST /api/apply-coupon	PB-04, PB-05, PB-06	3
PUT /api/admin/orders/:id/status	PB-02, PB-07, PB-08	3

PB-02 ảnh hưởng đồng thời Login và Admin Order Status nên tổng số ảnh xạ API lớn hơn tổng số nguyên nhân gốc.

3. Danh sách lỗi đã xác nhận

Bug ID	Tóm tắt	Mức độ	Endpoint	case_id/scenario_id chính	Yêu cầu/nguồn	GitHub Issue	Bảng chứng ảnh
PB-01	Login làm lộ mật khẩu dạng rõ và các trường tài khoản nhạy cảm	HIGH	POST /api/login	LOGIN-GEN-001/002/003/004/032/033/038, LOGIN-EXT-003	API specification Authentication 1.2; yêu cầu không làm lộ dữ liệu nhạy cảm	#1	PB-01.png
PB-02	Xử lý lỗi làm lộ stack trace, đường dẫn tuyệt đối và thông tin framework	HIGH	POST /api/login; PUT /api/admin/orders/:id/status	LOGIN-GEN-036, LOGIN-EXT-005, ORDERSTATUS-GEN-033/035	NO_INTERNAL_LEAKAGE; định nghĩa request body của hai API	#2	PB-02.png
PB-03	Tài khoản bị khóa sau hai lần đăng nhập sai thay vì ba lần	MEDIUM	POST /api/login	LOGIN-GEN-040 / LOGIN-GEN-040-A	FR-02	#3	PB-03.png
PB-04	Coupon từ chối khi total_amount = min_order_amount	MEDIUM	POST /api/apply-coupon	COUPON-GEN-006, COUPON-EXT-002-EQUAL	FR-09 C3	#4	PB-04.png
PB-05	API chấp nhận user_id dạng object và vẫn cấp giảm giá hợp lệ	HIGH	POST /api/apply-coupon	COUPON-GEN-025	API specification Coupons 5.1; kiểm tra type confusion	#5	PB-05.png

Bug ID	Tóm tắt	Mức độ	Endpoint	case_id/scenario_id chính	Yêu cầu/nguồn	GitHub Issue	Bảng chứng ảnh
PB-06	Coupon phần trăm tạo mức giảm âm và làm tăng <code>final_amount</code>	HIGH	POST <code>/api/apply-coupon</code>	COUPON-EXT-001	FR-09	#6	PB-06.png
PB-07	JWT của user thường có thể cập nhật trạng thái qua endpoint admin	CRITICAL	PUT <code>/api/admin/orders/:id/status</code>	ORDERSTATUS-GEN-010/011/031, ORDERSTATUS-EXT-001	FR-12, SEC-02, SEC-03	#7	PB-07.png
PB-08	Order đã <code>canceled</code> vẫn chuyển được sang <code>delivered</code>	HIGH	PUT <code>/api/admin/orders/:id/status</code>	ORDERSTATUS-EXT-003-CANCELED-TO-DELIVERED	FR-10	#8	PB-08.png

4. Kết quả thực tế nổi bật

- PB-01: response login 200 chứa `user.password`, `reset_token`, `login_attempts` và `locked_until`.
- PB-02: JSON malformed trả HTML có `SyntaxError`, stack frame và đường dẫn tuyệt đối; wrong `Content-Type` trên Order Status trả 500 kèm `TypeError` và thông tin source/framework.
- PB-03: đăng nhập bằng mật khẩu đúng sau hai lần sai trả 403 với thông báo tài khoản đã bị khóa.
- PB-04: `total_amount=200000` bằng đúng `min_order_amount=200000` nhưng API trả 400 và từ chối coupon.
- PB-05: request có `"user_id":{"$gt":0}` vẫn trả 200, `success=true` và mức giảm giá hợp lệ.
- PB-06: coupon 10% trên tổng 500000 trả `discount_amount=-450000` và `final_amount=500000`.
- PB-07: normal-user JWT gọi endpoint admin nhận 200; trạng thái order được lưu từ `pending` thành `confirmed`.
- PB-08: API chấp nhận chuyển trạng thái `canceled -> delivered` và lưu trạng thái `delivered`.

5. Bảng chứng thực thi

Bảng chứng chính:

- `reports/newman/login_run.json`
- `reports/newman/coupon_run.json`
- `reports/newman/order_status_run.json`
- `reports/newman/html`
- `reports/newman/order_status_rerun_after_automation_fix.json`
- `reports/analysis/newman_execution_analysis.md`
- `reports/analysis/order_status_automation_fix_review.md`

Bảng chứng bổ sung:

- Báo cáo chi tiết: `bug-reports/PB-01.md` đến `bug-reports/PB-08.md`.
- Ảnh thực thi: `bug-reports/screenshots/PB-01.png` đến `bug-reports/screenshots/PB-08.png`.
- Ảnh tổng thể GitHub Issue: `bug-reports/screenshots/githubissues.png`.
- Bản nội dung issue đã soạn: `bug-reports/github-issues/PB-01_issue.md` đến `PB-08_issue.md`.

Hai lỗi automation AF-01 và AF-02 không được tính là bug của SUT. Sau khi sửa assertion mode và chạy lại Order Status, các false failure liên quan đã biến mất; bằng chứng cho PB-02, PB-07 và PB-08 vẫn tái hiện.

6. Bảo toàn lịch sử đánh giá

- Phân tích AI ban đầu chỉ phân loại các phát hiện là `POTENTIAL_SUT_BUG`; quyết định xác nhận cuối cùng thuộc về người duyệt.
- Riêng PB-05, phân loại lịch sử của AI vẫn là `POTENTIAL_SUT_BUG` với confidence `Medium`. Quyết định của người duyệt được lưu riêng và xác nhận bug cho mục đích báo cáo; lịch sử AI không bị viết lại.
- Các báo cáo Newman gốc và báo cáo chạy lại sau khi sửa automation đều được giữ nguyên.
- Nhiều assertion cùng phản ánh một nguyên nhân gốc không bị tính thành nhiều bug riêng.

7. Điểm cần rà soát trước khi nộp

1. Tiêu đề GitHub Issue #6 hiện ghi đúng mã PB-06-FR09 nhưng phần mô tả ngắn trong tiêu đề bị sao chép từ PB-05. Body của issue vẫn mô tả đúng lỗi tính coupon phần trăm. Nên sửa tiêu đề thành: [PB-06-FR09] Coupon phần trăm trả mức giảm âm và làm tăng `final_amount`.
2. Mã requirement trong tiêu đề các issue #1, #2, #7 và #8 nên được đối chiếu lại với báo cáo chi tiết: PB-01/PB-02 không chỉ được xác lập từ FR-02, PB-07 ánh xạ FR-12 và SEC-02/SEC-03, PB-08 ánh xạ FR-10.
3. Các ảnh PB-01.png, PB-03.png, PB-07.png và PB-08.png hiển thị password hoặc JWT dùng trong lần chạy. Cần che các giá trị credential/token trước khi commit hoặc chia sẻ công khai; việc che dữ liệu không được làm mất phần response chứng minh hành vi lỗi.